

UE8 · Système d'information de gestion

La sécurité et la durabilité du système d'information

40 heures au programme officiel du DCG 2027

Introduction

La numérisation croissante des organisations s'accompagne de risques nouveaux, qu'ils touchent à la sécurité des données, au respect du cadre légal, ou à l'impact environnemental des infrastructures numériques. Ce chapitre étudie ces trois dimensions, indissociables d'une gestion responsable du système d'information contemporain.

1. Les enjeux juridiques et réglementaires

1.1 Le RGPD

Le Règlement Général sur la Protection des Données (RGPD), entré en application en 2018, encadre au niveau européen la collecte et le traitement des données à caractère personnel. Il repose sur plusieurs principes cardinaux : la **licéité** du traitement (toute collecte de données personnelles doit reposer sur une base légale, comme le consentement de la personne concernée) ; la **minimisation** des données (ne collecter que les données strictement nécessaires à la finalité poursuivie) ; la **limitation de la conservation** (ne pas conserver les données au-delà de la durée nécessaire) ; et les droits reconnus aux personnes concernées, notamment le droit d'accès, de rectification et d'effacement de leurs données.

1.2 Le délégué à la protection des données

Certaines organisations doivent désigner un délégué à la protection des données (DPO, Data Protection Officer), chargé de veiller à la conformité de l'organisation avec le RGPD, de conseiller les équipes internes et de constituer un point de contact avec l'autorité de contrôle (en France, la CNIL).

1.3 Les obligations relatives aux fichiers informatisés obligatoires

Les organisations sont soumises à diverses obligations légales concernant l'établissement, la conservation et la transmission de certains fichiers informatisés : le fichier des écritures comptables (FEC), la déclaration sociale nominative (DSN), la liasse fiscale, ou encore la déclaration de TVA. Ces obligations impliquent également des exigences de sauvegarde et de confidentialité des données concernées, en particulier lorsqu'elles touchent à des informations personnelles sensibles.

2. Les enjeux de cybersécurité

2.1 Les principales menaces

Les organisations sont exposées à des menaces informatiques variées. Le **rançongiciel** (ransomware) est un logiciel malveillant qui chiffre les données de sa victime et exige le paiement d'une rançon pour en restaurer l'accès. Le **phishing** (hameçonnage) est une technique frauduleuse consistant à tromper un utilisateur, souvent par un email ou un site imitant une source légitime, afin de lui soutirer des informations confidentielles (identifiants, coordonnées bancaires).

2.2 Les principes fondamentaux de la sécurité informatique

La sécurité d'un système d'information repose sur trois exigences cumulatives, souvent résumées par l'acronyme DIC : la **disponibilité** (les systèmes et données doivent être accessibles aux utilisateurs autorisés quand ils en ont besoin), l'**intégrité** (une donnée ne doit pas être altérée de façon non autorisée) et la **confidentialité** (seules les personnes autorisées doivent pouvoir accéder à une information donnée).

2.3 Les dispositifs de protection

Plusieurs dispositifs techniques et organisationnels permettent de renforcer la sécurité du SI : le **pare-feu** (firewall), qui filtre les flux entrants et sortants d'un réseau pour bloquer les accès non autorisés ; l'**authentification à deux facteurs**, qui exige deux preuves d'identité distinctes pour accéder à un compte ou un système, renforçant la protection contre le vol d'identifiants ; et les **sauvegardes régulières** des données, qui permettent leur restauration en cas de perte, d'attaque ou de sinistre.

2.4 Le plan de continuité d'activité

Un plan de continuité d'activité (PCA) est un dispositif préparé en amont, qui permet à une organisation de maintenir ou de reprendre rapidement son activité après un incident majeur touchant son système d'information (cyberattaque, panne majeure, catastrophe naturelle).

2.5 Le facteur humain

La majorité des failles de sécurité exploitées par des attaquants proviennent en réalité d'erreurs humaines : mots de passe trop simples ou réutilisés, clics sur des liens frauduleux, absence de vigilance face à une tentative de phishing. La sensibilisation et la formation régulière des utilisateurs constituent donc un pilier aussi important que les dispositifs techniques dans une politique de sécurité informatique efficace.

3. La durabilité du système d'information

3.1 Les impacts environnementaux du numérique

Le numérique génère des impacts environnementaux à la fois négatifs et positifs. Parmi les impacts négatifs figurent la surconsommation énergétique des data centers, la multiplication des terminaux électroniques et leur obsolescence rapide, ou encore l'extraction de ressources rares nécessaires à leur fabrication. Parmi les impacts positifs, on peut citer la dématérialisation de certaines démarches, qui peut réduire certains déplacements physiques, ou la réduction de la consommation de papier.

3.2 La loi REEN

En France, la loi relative à la Réduction de l'Empreinte Environnementale du Numérique (loi REEN) encadre les pratiques numériques des organisations, en les incitant à adopter des comportements plus responsables, sans imposer d'obligations techniques ou de certification environnementale détaillées, mais en sensibilisant aux bonnes pratiques.

3.3 Les pratiques de sobriété numérique

Une gestion plus durable du système d'information passe par des pratiques concrètes à plusieurs niveaux : une gestion raisonnée de l'énergie consommée par les infrastructures informatiques, un choix et une gestion responsables des équipements matériels (allongement de leur durée de vie, réemploi, recyclage), et une évolution des comportements numériques individuels (limitation des envois de fichiers volumineux inutiles, suppression des données obsolètes...).

4. Application pratique

Une entreprise victime d'une attaque par rançongiciel constate que ses données comptables sont chiffrées et inaccessibles. Grâce à un plan de continuité d'activité prévoyant des sauvegardes régulières et externalisées de ses données, elle parvient à restaurer son système sans céder à la demande de rançon, limitant ainsi l'impact de l'attaque sur son activité. Cet exemple illustre l'importance cruciale des sauvegardes régulières, l'un des dispositifs les plus simples et les plus efficaces de la politique de sécurité informatique.

Points clés à retenir

- Le RGPD encadre la collecte et le traitement des données personnelles selon les principes de licéité, minimisation et limitation de conservation.
- La sécurité informatique repose sur trois principes : disponibilité, intégrité, confidentialité (DIC).
- Rançongiciel et phishing sont deux menaces informatiques majeures ; pare-feu, authentification à deux facteurs et sauvegardes sont des dispositifs de protection clés.
- La majorité des failles de sécurité proviennent d'erreurs humaines, d'où l'importance de la sensibilisation.
- La loi REEN encadre les pratiques numériques responsables face aux impacts environnementaux du numérique.

Pièges à l'examen

Ne réduisez jamais la cybersécurité aux seuls dispositifs techniques : le programme insiste explicitement sur le facteur humain, à l'origine de la majorité des incidents de sécurité. De même, gardez à l'esprit que la durabilité numérique s'aborde ici de façon qualitative (bonnes pratiques, sensibilisation) et non quantitative (pas de calcul de bilan carbone ni d'analyse de cycle de vie détaillée attendus dans ce programme).